



File No.: EXP202414356

RESOLUTION OF TERMINATION OF THE PROCEDURE FOR RECOGNITION OF RESPONSIBILITY AND VOLUNTARY PAYMENT

From the procedure initiated by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: On April 12, 2025, the Presidency of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against A.A.A. (hereinafter, A.A.A.), through the agreement that is transcribed:

<<

File No.: EXP202414356

AGREEMENT TO INITIATE SANCTIONING PROCEDURE

From the actions carried out by the Spanish Agency for Data Protection and based on the following

FACTS

FIRST: The Spanish Agency for Data Protection (AEPD) has become aware of certain facts that could constitute possible infringements attributable to A.A.A. with NIF ***NIF.1 (hereinafter, A.A.A., the pharmacy, or the reported party), as the owner of the pharmacy office ***NIF.2, following a complaint filed by the Direcció General D'Ordenació i Regulació Sanitària of the Autonomous Community of Catalonia, after conducting inspections of pharmacy offices in the exercise of its competencies. The complaint was received by the AEPD on September 7, 2023, sent by the Autoritat Catalana de Protecció de Dades in compliance with Article 14 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector.

In it, the Direcció General D'Ordenació i Regulació Sanitària alerts about possible violations of data protection regulations regarding the processing of personal data of residents in geriatric centers by certain pharmacy offices, including, among others: alleged unauthorized access and transfers of personal health data or the exchange of personal data through insecure electronic means.

SECOND: As a consequence of the known facts, on October 19, 2023, the Director of the Spanish Agency for Data Protection urged the General Subdirectorate of Data Inspection (SGID) to initiate the preliminary investigation actions referred to in Article 67 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter, LOPDGDD).

All this in order to collect the necessary elements of judgment to thoroughly understand the described facts and the treatments carried out to, if applicable, determine the consequences that may arise from them for the rights and freedoms of individuals.

THIRD: The General Subdirectorate of Data Inspection proceeded to carry out preliminary investigation actions to clarify the facts in question, by virtue of the functions assigned to control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions of Title VIII of the LOPDGDD.

As a result of the actions carried out, the following points have been noted:

1. Regarding the information provided by the Pharmacy Inspection Service.

In its response letter, dated January 22, 2024, the Pharmacy Inspection Service provides the following information regarding the pharmacy A.A.A.:

“According to the information available to this Pharmacy Inspection Service regarding the billing of medications by the Servei Català de la Salut (CatSalut), the urinary incontinence absorbents (diapers) dispensed to the residents of ***RESIDENCIA.1 are not billed to Pharmacy B.B.B. (***NIF.3) but to another pharmacy office, ***NIF.2, located at ***DIRECCIÓ.1, whose owner is A.A.A. (hereinafter Pharmacy A.A.A.).

For this reason, on November 23, 2023, an inspection was carried out at Pharmacy A.A.A. (***NIF.2):

- During the inspection, the owner of the pharmacy office confirmed that the diapers for the residents of ***RESIDENCIA.1 were dispensed from his pharmacy office.

- That about 2 years ago Mr. C.C.C. (presented through the manager of ***EMPRESA.1) proposed to him to dispense diapers to a residence to which “his pharmacy” dispensed medications in SPD.
- Mr. A.A.A. reported that he initially worked with Pharmacy D.D.D. (***NIF.4), located at ***DIRECCIÓN.2 and now with Pharmacy B.B.B. (***NIF.3), and that at first he dispensed diapers for the residents of ***RESIDENCIA.2 and since mid-2023 he did so for the residents of ***RESIDENCIA.1, at the suggestion of Pharmacy B.B.B. (***NIF.3).
- The owner of Pharmacy A.A.A. (***NIF.2) confirmed that he had no contact with the residences or the residents and that Pharmacy B.B.B. (***NIF.3) had provided him with access codes to the software program ***PROGRAMA.1 with which he obtained the CIP of the residents to access their electronic prescriptions and dispense the diapers, which he related in the Excel files sent by email from ***EMAIL.1. Subsequently, he sent an email with the list of monetary contributions from the residents, which were paid to him by Pharmacy B.B.B. (***NIF.3).”

C/ Jorge Juan, 6
 www.aepd.es
 28001 – Madrid
 sedeaepd.gob.es
 3/45

Furthermore, the Pharmacy Inspection submits the minutes of the inspection carried out on November 23, 2023, the content of which is reproduced below:

(...)

1.1 Annexes of the Inspection Minutes.

These minutes include the following evidence:

- Annex I: email dated 11/16/2023 containing an exchange of emails between the email addresses ***EMAIL.1 and ***EMAIL.2 in which an Excel document titled “***EXCEL.1” is attached, containing the names and surnames of the residents of the ***RESIDENCIA.3 who have diapers available that week.
- Annex II: email dated 11/17/2023 sent from the email account ***EMAIL.2 to the email address ***EMAIL.1 and copied to ***EMAIL.4 with the text: “Attached are sales and contributions from November 17.” The email includes an attached Excel document titled “***EXCEL.2” which contains, among other information, the names and surnames of residents of ***RESIDENCIA.3.

1.

Information provided in response to the information requests from the AEPD.

On 11/06/2024, an information request is made to the reported party, asking for, among other points, the list of residences to which it provides or has provided services, a description of the treatments performed and their legal basis, a copy of the RAT, the Risk Analysis, and the Impact Assessment (hereinafter, EIPD), as well as information about the exchange of personal data with third parties. The reported party responds to this information request, with an entry registration date of 11/20/2024, providing only a document that includes the following information:

- Activity Register.
- Risk analysis.
- Brief summary of actions that the holders of the pharmacy office must take to comply with the GDPR.

2.1.

Residences to which it provides or has provided services.

The reported party offers in its response to the request the list of residences to which it provides services along with the start and end dates. It states that it provides dispensing services for urinary incontinence pads to the residents of these centers.

- ***RESIDENCIA.4 from 2019 to present. 6 residents

C/ Jorge Juan, 6
 www.aepd.es
 28001 – Madrid
 sedeaepd.gob.es

- ***RESIDENCIA.5 from June 2024 to present. 19 residents
- ***RESIDENCIA.2 from 01/20/21 to 04/25/23. An average of 20 residents
- ***RESIDENCIA.6 from 05/10/23 to 11/23/23. An average of 20 residents

The reported party indicates that the treatments performed on the personal data of the residents are: collection, consultation, and communication.

It also states that the holder of the Pharmacy Office acts as the data controller and that the legal basis is the Law on Guarantees and Rational Use of Medicines and Health Products.

2.1.

Contracts with the residences.

When requested for a copy of the contracts signed with each of the residences that include, where applicable, the corresponding data processing agreement, the reported party states that:

“Does not apply because the holder of the Pharmacy Office acts as the data controller.”

2.2.

Procedures followed to comply with the duty to inform residents.

Regarding the procedures followed to comply with the duty to inform residents, the reported party states in its response to the request that:

“We had no contact with the residents. All the information was received through the intermediary pharmacy.”

2.3.

Documentation required by GDPR.

The reported party provides the following information included in its response to the request:

- Activity Register.
- Risk analysis.
- Brief summary of actions that the holders of the pharmacy office must take to comply with the GDPR.

2.1.

Activity Register (RAT).

The reported party provides as the Activity Register a single treatment. The following information is extracted, among others:

- Medical Prescription from the National Health System (Electronic and/or paper format) or charged to work accident mutuals
- Special category data in mixed ownership format
- Name or corporate name of the data file holder: Servei Català de Salut, MUFACE, ISFAS, and MUGEJU, and the different Work Accident Mutuals
- Responsible: A.A.A.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeapd.gob.es

5/45

-

Purpose and intended uses: Dispensing of medications prescribed by the SNS with electronic prescription.

-

Special category data: Health

-

Software applications: RE System (Electronic Prescription)

Add the general information of this treatment shown below:

“The data controllers are CATSALUT, MUFACE, ISFAS, and MUGEJU, as well as the various Work Accident Mutuals.

These are public ownership files, so the obligation to inform about the content and purpose of the file is understood to be fulfilled with the publication in the official bulletins of the agreement to create the file,

prior to the application of the European GDPR.

Data controller: The pharmacist who is the owner of the pharmacy may also be a data controller, and, where applicable, the managing pharmacist.

High-level technical and organizational security measures must be adopted.

The owner pharmacist of the pharmacy does not decide on the purpose of the file. They can only, as provided by the Law on Guarantees and Rational Use of Medicines and Health Products 29/2006 of July 26, and RD 1718/2010 on Medical Prescription and RD 1675/2012 on Medical Prescription of Narcotics, retain, store, and process the data corresponding to the medication or product dispensed, the price, and the reference of the pharmacy, for billing purposes. In the event that the pharmacy owner intends to use the data beyond what is provided for in current regulations, they must obtain the consent of the affected party, following the guidelines set out for Customer files, Pharmaceutical Care, SPD, Orthopedics, according to the purpose for which the data is obtained.

In some cases, the pharmacy owner needs to obtain services from third parties to dispense the medication or product prescribed in the prescription. This is the case for magistral formulas and vaccines.

The owner pharmacist has data processors when they commission another pharmacy owner to carry out the magistral formulas or commission the laboratory for individualized vaccines.

The College of Pharmacists is a data processor when it issues invoices and manages the collection of medications and other products dispensed with prescriptions from the National Health System or from work accident mutuals. Apart from the IT providers of the systems used, who are always considered data processors.

The file that contains the personal data of the pharmaceutical service of the “Servei Català de la Salut” is a public ownership file, whose registration with the APDCAT occurred through Order 288/1999 of October 26.”

2.1.

Technical reports from the DPD.

Requested technical reports or recommendations prepared by the Data Protection Officer, the reported party includes the information, “Brief relationship of actions that pharmacy owners must take to comply with GDPR” and indicates access to the electronic document at ***URL.1, requiring a username and password to access said webpage.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaeapd.gob.es

6/45

The information on this webpage, among other points, specifies:

“In accordance with the content of the Personal Data Protection Protocol, the owner must:

[...]

4. Obtain the explicit consent of clients/users for the processing of their personal data. Have Clause B.1 of Annex B signed by clients-patients.

5. Have contracts signed with the Data Processors described in Annex C, the model contract C.1 with the IT company, the management company that processes payroll, the security company if applicable, etc., and model C.2 with the pharmacy owner who carries out the magistral formulas by commission.

[...]

21. The telematic sending of magistral formulas and vaccines must be done securely: either by fax dissociating the data, or by ordinary mail to the formulator or distributor in the case of vaccines, or by encrypted email.”

3.

Third-party entities

The reported party states in their response to the request, information about third-party entities related to their pharmacy that carry out processing of personal data of residents:

“our only contact was through the pharmacy.

Pharmacy E.E.E. from 25-01-21 to 28-10-22

Pharmacy B.B.B. from 14-11-22 to 23-11-23

The diapers were provided by our official distributor ***EMPRESA.1 or ***EMPRESA.2 who introduced us to C.C.C. to dispense the diapers from ***RESIDENCIA.2.

The obtaining of the electronic prescription was carried out through the software program ***PROGRAMA.1.”

When requested to describe the processing carried out by those third-party entities on the personal data of the residents, the reported party indicates:

“Through an Excel sheet, the pharmacy sent us the information about which patients we had to dispense the diapers.”

When asked about the legal basis that legitimizes such processing in particular, the reported party does not answer this specific question.

Regarding the contracts with data processors, the reported party states:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaeprd.gob.es

7/45

“In the case of the residences ***RESIDENCIA.5 and ***RESIDENCIA.4, we have all the authorizations according to the model required by the College of Pharmacists of Barcelona, duly completed by the patient or, in default, by the responsible person.”

4.

Exchange of personal data information of the residents.

When consulted about the procedure for exchanging personal data information between the pharmacy and the residences, the accused party responds:

“5.1 There was no contact with the residences ***RESIDENCIA.2 or ***RESIDENCIA.6. In the case of the other residences, we have all the information duly authorized by the patient to access their data and send the diapers. Through an encrypted email, they indicate which patients need diapers. These are sent to us by ***EMPRESA.1 to the pharmacy, and from there we send them to the residence.”

When consulted about the procedure for exchanging personal data information between the pharmacy and other third entities, the accused party responds:

“5.2 In the case of the residences ***RESIDENCIA.2 and ***RESIDENCIA.6, the exchange of information was obtained through an Excel file that the pharmacy sent us. Through the program ***PROGRAMA.1 and a user code that they provided, we could see the code of the electronic prescription and thus dispense the diapers that they had not indicated we needed to dispense.”

5.

Use of software, Excel sheets, or similar for the collection of residents' data.

When consulted about the use of software, Excel sheets, or similar for the collection of residents' data, the accused party states in their response to the request:

“The information about the diapers that we had to sell to the residences ***RESIDENCIA.2 and subsequently to ***RESIDENCIA.6 came to us through an Excel file that indicated to whom we should sell the diapers. The information from the electronic prescription was obtained through the program ***PROGRAMA.1, which we accessed using a user code that was provided to us.”

6.

Program ***PROGRAMA.1

When requested to confirm the use of the program ***PROGRAMA.1 to access the data of the residents and information about the type of data obtained from said program, the accused party indicates:

“8.1 The program ***PROGRAMA.1 was used to obtain the data from the electronic prescription.

8.2 We could only access the number of their electronic prescription based on the user level we had.”

C/ Jorge Juan, 6

www.aepd.es
28001 – Madrid
sedeaepd.gob.es

8/45

When requested to confirm possession of a personal user in the program ***PROGRAMA.1, the accused party states:

“8.3 At the beginning of contacting the pharmacy E.E.E., we were sent via email the relevant username and password.”

FOURTH: The pharmacy ***NIF.2 is owned by A.A.A. with NIF ***NIF.1.

LEGAL GROUNDS

I

Competence

According to the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter, LOPDGDD), the Presidency of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

II

Procedure

Furthermore, Article 63.2 of the LOPDGDD states: “The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, this Organic Law, the regulatory provisions issued for its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures.”

In accordance with Article 64 of the LOPDGDD, and considering the characteristics of the alleged infringements committed, a sanctioning procedure is initiated.

The procedure will have a maximum duration of twelve months from the date of the initiation agreement. After this period, it will expire, and consequently, the file of actions will be archived, in accordance with the provisions of Article 64 of the LOPDGDD.

If no allegations are made regarding this initiation agreement within the stipulated period, it may be considered a proposal for resolution, as established in Article 64.2.f) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP).

III

Preliminary issues

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaepd.gob.es

9/45

1. Applicable sectoral regulations

1.1. Pharmacies

Pharmacies are, according to Article 86.6 of Royal Legislative Decree 1/2015, of July 24, which approves the consolidated text of the Law on guarantees and rational use of medications and health products, private health establishments of public interest.

Their regulation is found, among other applicable norms, in Law 14/1986, of April 25, General Health Law; Law 16/1997, of April 25, on the Regulation of Pharmacy Office Services; Royal Legislative Decree 1/2015, of July 24, which approves the consolidated text of the Law on guarantees and rational use of medications and health products; as well as in the applicable regional legislation such as, in the case of Catalonia, Law 31/1991, of December 13, on the Pharmaceutical Regulation of Catalonia.

Both Law 14/1986, of April 25, and Law 16/1997, of April 25, state:

“The pharmacist owner of the pharmacy, assisted, where appropriate, by assistants or auxiliaries, must provide the following basic services to the population:

1. The acquisition, custody, conservation, and dispensing of medications and health products.
2. The monitoring, control, and custody of dispensed medical prescriptions (...).

For its part, Article 3 of Royal Legislative Decree 1/2015, of July 24, is more emphatic in stating that the custody, conservation, and dispensing of medications for human use corresponds exclusively to:

"a) Pharmacies open to the public, legally authorized.

b) The pharmacy services of hospitals, health centers, and primary care structures of the National Health System for their application within such institutions or for medications that require particular monitoring, supervision, and control by the multidisciplinary health care team, in accordance with the qualification granted by the Spanish Agency for Medicines and Health Products for such medications (...).

Pharmacies are obliged, according to Article 86.3 of Royal Legislative Decree 1/2015, of July 24, to "dispense medications requested by both individuals and the National Health System under the established regulatory conditions." However, the principle of free choice of pharmacy must be respected. Thus, this regulation establishes as a serious infringement in its Article 111 b):

"26th. To restrict the user's freedom in choosing the pharmacy through any act or omission."

It is also classified as a serious infringement in the same article:

"22nd. To defraud the National Health System or its beneficiaries regarding the billing and collection of official prescriptions."

It is also emphasized that, according to the aforementioned Royal Legislative Decree, it constitutes a very serious infringement according to Article 111 c):

"23rd. For pharmacies to carry out activities of distributing medications to other pharmacies, authorized distribution entities, or other entities, centers, or individuals without authorization for distribution activities or to carry out shipments of medications outside the national territory."

For its part, Law 16/1997, of April 25, enshrines the figure of the pharmacist as an essential and indispensable element for the operation of a pharmacy by determining in its Article 5:

"1. The presence and professional action of a pharmacist is an inexcusable condition and requirement for the public dispensing of medications. The collaboration of assistants or auxiliaries does not excuse the pharmacist's action in the pharmacy while it remains open to the public, nor does it exclude their professional responsibility.

2. The Autonomous Communities may regulate the minimum number of assistant pharmacists, in addition to the owner, who must provide services in pharmacies to ensure adequate professional assistance to users. This regulation must take into account, among other factors, the volume and type of activity of the pharmacies and the service hours regime.

3. Without prejudice to the action of the assistant, the pharmacist owner shall be responsible for ensuring service to users."

Furthermore, Article 103 of Law 14/1986, of April 25, General Health Law states:

"1. The custody, conservation, and dispensing of medications shall correspond to:

a) Legally authorized pharmacies.

b) The pharmacy services of hospitals, health centers, and primary care structures of the National Health System for their application within such institutions or for those that require particular monitoring, supervision, and control by the multidisciplinary health care team.

2. Pharmacies open to the public are considered health establishments for the purposes provided in Title IV of this Law.

3. Pharmacies will be subject to health planning under the terms established by the special legislation on medications and pharmacies.

4. Only pharmacists may be owners and holders of pharmacies open to the public."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeapd.gob.es

11/45

Consequently, the owner of the pharmacy is the one who is responsible for the actions carried out by the pharmacy office and to whom responsibilities can be demanded.

1.2 Dispensing of Medications

In addition to the aforementioned regulations, the Royal Decree 1718/2010, of December 17, on medical prescriptions and dispensing orders is of interest in the field of pharmaceutical dispensing, whose Chapter IV is dedicated to "the official electronic medical prescription of the SNS," outlining the general criteria for its development, as well as coordination within the SNS. In its Article 9, it states:

"1. Dispensing shall be carried out by pharmacies connected to the electronic medical prescription system, through the standardized procedure established by the competent health authorities, which will determine its specific conditions, requiring the electronic certificate of the pharmacy owner, or, where applicable, of the managing, assistant, or substitute pharmacist, issued by the competent entity.

2. After the unequivocal identification of the patient, and where applicable, the person to whom they delegate, the pharmacist may only access, from the equipment installed in the pharmacy, the necessary data for a correct informed dispensing and treatment follow-up, and will dispense exclusively, from among the pending prescriptions, those requested by the patient.

3. Access to the electronic system by pharmacists will only be permitted through the patient's health card duly recognized by the electronic prescription system, which must be returned immediately to its holder and cannot be retained in the pharmacy. The pharmacist's access will always be recorded in the aforementioned system.

4. At the time of dispensing, the electronic prescription systems must incorporate and send to the corresponding health administrations the identification data of the dispensed product, coded according to the official nomenclature of pharmaceutical products of the National Health System, the number of dispensed packages and their unit identification when possible, identification of the dispensing pharmacy, using the NIF/CIF of its owner, as well as the identification number of the pharmacy granted by the competent health administration, and the date of dispensing, in the format established by the national exchange node for this purpose. This information will be the only one retained for billing purposes in the collegiate pharmaceutical organization, as long as it acts as the responsible entity, and will be available to the competent health administrations in accordance with their applicable regulations."

Furthermore, in its Article 11, it determines:

"The electronic medical prescription system will guarantee the security in access and transmission of information, as well as the protection of the confidentiality of data, in accordance with the provisions of Organic Law 15/1999, of December 13, on the protection of personal data. High-level security measures, as provided in the aforementioned regulations, will be implemented."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeae@epd.gob.es

12/45

protection of personal data. To ensure these levels of security, this information will only be accessible from the pharmacy for dispensing purposes, will reside permanently in the electronic prescription systems managed by the health administrations, and may not be stored in repositories or servers external to these, established for billing purposes, once it has occurred."

At the regional level, in Catalonia, Royal Decree 159/2007, of July 24, stands out, regarding Electronic Prescription and the telematic processing of pharmaceutical services under the Catalan Health Service.

Lastly, it is worth noting Order SLT/72/2008, of February 12, which develops Decree 159/2007, of July 24, regulating electronic prescriptions and the telematic processing of pharmaceutical services under the Catalan Health Service. Article 7 states:

"In order to access the dispensing of electronic prescriptions, the patient must be identified as the holder of the right to pharmaceutical services at the pharmacy by presenting the individual health card, and must provide the pharmacist with the active medication sheet that includes the treatment for which the dispensing of the product included in the pharmaceutical service is requested."

2. On the presumption of veracity of the acts of the Pharmacy Inspection

Article 108 of Royal Legislative Decree 1/2015, of July 24, which approves the consolidated text of the Law on guarantees and rational use of medications and health products, states that it is the responsibility of the health administrations within their competencies to carry out the necessary inspections to ensure compliance with the provisions of this law.

This article practically reproduces what is provided for in Article 30 of Law 14/1986, of April 25, General Health Law, which determines that “all health centers and establishments, as well as promotional and advertising activities, shall be subject to inspection and control by the competent Health Administrations.”

Both regulations provide, in their Articles 108.3 and 31 respectively, for such purposes, a series of powers for personnel in the service of Public Administrations in the exercise of inspection authority, including the possibility of entering freely and without notification into the centers subject to them, such as pharmacies; as well as proceeding with the tests, investigations, or examinations necessary to verify compliance with regulations; taking samples, in order to verify compliance with them, as well as carrying out any actions necessary to fulfill the inspection functions they perform.

At the regional level, Law 26/2010, of August 3, on the legal regime and procedure of public administrations in Catalonia, enshrines in its Article 89.2 the consideration of authority of the personnel of its Administration responsible for public inspection and control functions.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeae@pd.gob.es

13/45

In this regard, it is worth noting that Article 77.5 of the LPACAP establishes the presumption of veracity of documents signed by public employees who are considered authorities, unless proven otherwise. Specifically, it states: “documents formalized by officials recognized as authorities and which, observing the corresponding legal requirements, record the facts established by them, shall serve as proof of these facts unless proven otherwise.”

In the same vein, the aforementioned Law 26/2010, of August 3, of Catalonia in its Article 90.1 determines that the facts established by the Administration personnel responsible for public inspection and control functions, and which are formalized in a public document observing the legally established requirements, have evidentiary value, without prejudice to the evidence that may be provided by interested parties in defense of their rights and interests.

Consequently, the minutes must be signed unavoidably by the inspector, without prejudice to the fact that the lack of signature by the inspected party does not invalidate the minutes or their evidentiary value.

3. Responsibility for processing in the field of personal data protection

Article 4.1) of the GDPR defines “personal data” as: “any information relating to an identified or identifiable natural person (‘the data subject’); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier, such as a name, an identification number, location data, an online identifier, or one or more specific elements of the physical, physiological, genetic, mental, economic, cultural, or social identity of that natural person.”

Article 4.2) of the GDPR defines “processing” as: “any operation or set of operations performed on personal data or sets of personal data, whether by automated means or not, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, communication by transmission, dissemination or otherwise making available, alignment, combination, restriction, erasure or destruction.”

Article 4.7) of the GDPR defines the “data controller” or “controller” as: “the natural or legal person, public authority, agency, or other body that, alone or jointly with others, determines the purposes and means of the processing; where the law of the Union or of the Member States determines the purposes and means of processing, the controller or the specific criteria for its designation may be provided by the law of the Union or of the Member States.” In turn, Article 4.8) of the GDPR defines the “processor” as the natural or legal person, public authority, agency, or other body that processes

personal data on behalf of the controller.

For its part, the Guidelines 07/2020 of the European Data Protection Board on the concepts of “data controller” and “data processor” (hereinafter, Guidelines 07/2020) emphasize that the concepts of data controller and data processor are functional concepts, being necessary.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeapd.gob.es

14/45

establish them by virtue of their specific activities in the analyzed case and not based on the formal designation that may appear in the contract:

“12. The concepts of ‘data controller’ and ‘data processor’ are functional concepts: their purpose is to assign responsibilities based on the actual role of each party. This implies that the legal status of ‘data controller’ or ‘data processor’ of the participants must be established, in principle, by virtue of their specific activities in a given situation and not based on the formal designation of a participant as ‘data controller’ or ‘data processor’ (e.g., in a contract). This implies that the assignment of the role of controller or processor must normally derive from an analysis of the facts or circumstances of the case and, consequently, is not negotiable.” (underlined by the AEPD).

In short, the identification of the controller must be carried out according to material criteria in accordance with the actual conditions and circumstances of each processing operation; it cannot be understood as a mere formal acknowledgment of what is stated, for example, in a contract signed between parties. Thus, there will be occasions when the participants in a chain of processing operations have been identified respectively as controller and processor, and yet, based on who determines the purpose of the processing and the essential means thereof, the role of controller corresponds to the one who was formally identified as such.

In addition to what has been stated so far, it should be noted that these Guidelines from the EDPB highlight:

“20. (...) The data controller is the one who decides on certain essential aspects of the data processing. The responsibility for processing can be established in the regulation or inferred from an analysis of the facts or circumstances of the case. It is necessary to focus on the specific processing activities in question and understand who determines them. To do this, the following questions must first be examined: ‘Why is the processing taking place?’ and ‘Who has decided that the processing should be carried out for a specific purpose?’.” (underlined by the AEPD).

Furthermore, the aforementioned EDPB Guidelines 07/2020 advocate for a broad interpretation of the concept of data controller in order to promote effective and comprehensive protection of the data subjects. In this regard, they provide:

“14. Since the ultimate goal of assigning the role of data controller is to ensure proactive responsibility and effective and comprehensive protection of personal data, the concept of ‘controller’ should be interpreted broadly enough to promote, as far as possible, effective and comprehensive protection of data subjects, in order to ensure the full effectiveness of Union law on data protection, avoid gaps, and prevent possible circumventions of the regulation, without this implying a reduction of the powers of the data processor.” (underlined by the AEPD).

On the other hand, as stated in Article 4.7 of the GDPR, it is possible that at times a regulation may define the controller, either implicitly or explicitly. Thus, it may occur that a regulation establishes obligations that imply

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeapd.gob.es

15/45

personal data processing and entrust it to a specific entity, which will have the status of data controller from the perspective of data protection.

In this case, according to the provisions of Articles 4.1 and 4.2 of the GDPR, there is evidence of

personal data processing, since the provision of diapers carried out by A.A.A. involves a set of operations performed on personal data such as accessing the personal data contained in the National Health System (SNS), its consultation and verification, as well as its structuring and organization. According to the documentation provided by A.A.A. in response to the preliminary investigation request from this Agency, in the Record of Processing Activities submitted, this pharmacy appears as the "data controller." This is corroborated by the investigated party in their responses to said investigation. In light of the above, A.A.A. carries out this activity in its capacity as the data controller, as it is the one who determines the purposes and means of such activity, pursuant to Article 4.7 of the GDPR.

4. Health data as a special category of data.

Article 9 of the GDPR, which regulates the processing of special categories of personal data, establishes the following:

"1. The processing of personal data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, or trade union membership, and the processing of genetic data, biometric data aimed at uniquely identifying a natural person, data concerning health or data concerning a natural person's sex life or sexual orientation is prohibited.

2. Paragraph 1 shall not apply when one of the following circumstances applies:

- a) the data subject has given explicit consent to the processing of such personal data for one or more specified purposes, except where Union or Member State law provides that the prohibition referred to in paragraph 1 may not be lifted by the data subject;
- b) the processing is necessary for compliance with a legal obligation to which the data controller is subject or for the establishment, exercise, or defense of legal claims;
- c) the processing is necessary to protect vital interests of the data subject or another natural person, in the event that the data subject is not physically or legally capable of giving consent;
- d) the processing is carried out, in the course of its legitimate activities and with appropriate safeguards, by a foundation, association, or any other body without a profit motive, provided that the processing relates solely to the members of the body or to persons who have regular contact with it in connection with its purposes."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sede@aepd.gob.es

16/45

non-profit, whose purpose is political, philosophical, religious, or trade union-related, provided that the processing refers exclusively to current or former members of such organizations or to individuals who maintain regular contact with them in relation to their purposes and provided that personal data is not communicated outside of them without the consent of the data subjects;

e) the processing refers to personal data that the data subject has made manifestly public;

f) the processing is necessary for the formulation, exercise, or defense of claims or when courts act in the exercise of their judicial function;

g) the processing is necessary for reasons of essential public interest, based on Union law or the laws of Member States, which must be proportional to the pursued objective, respect in essence the right to data protection, and establish adequate and specific measures to protect the interests and fundamental rights of the data subject;

h) the processing is necessary for the purposes of preventive or occupational medicine, assessment of the worker's capacity, medical diagnosis, provision of health or social care assistance or treatment, or management of health and social care systems and services, based on Union law or the laws of Member States or under a contract with a healthcare professional and without prejudice to the conditions and guarantees set out in paragraph 3;

i) the processing is necessary for reasons of public interest in the field of public health, such as protection against serious cross-border health threats, or to ensure high standards of quality and safety of healthcare and of medicines or medical products, based on Union law or the laws of Member States that establish adequate and specific measures to protect the rights and freedoms of the data subject, in particular professional secrecy;

j) the processing is necessary for archiving purposes in the public interest, for scientific or historical research purposes, or for statistical purposes, in accordance with Article 89, paragraph 1, based on Union law or the laws of Member States, which must be proportional to the pursued objective, respect in essence the right to data protection, and establish adequate and specific measures to protect the interests and fundamental rights of the data subject.

3. The personal data referred to in paragraph 1 may be processed for the purposes mentioned in paragraph 2, letter h), when the processing is carried out by a professional subject to the obligation of professional secrecy, or under their responsibility, in accordance with Union law or the laws of Member States or with the standards established by the competent national authorities, or by any other person also subject to the obligation of secrecy in accordance with Union law or the laws of Member States or the standards established by the competent national authorities.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeae@epd.gob.es

17/45

4. Member States may maintain or introduce additional conditions, including limitations, regarding the processing of genetic data, biometric data, or health-related data."

It should be noted that special category data are those personal data whose processing requires enhanced protection due to their special impact on privacy, public freedoms, and fundamental rights of the individual.

As such, their processing is, in principle, prohibited by the GDPR, unless one of the circumstances indicated in Article 9.2 of the GDPR exists.

Therefore, special category data are personal data that, due to their importance for the individual's privacy, must be processed with greater care and following special requirements.

Recital 71 states: "Regarding automated decisions and profiling, data controllers must use methods that correct 'the factors that introduce inaccuracies in personal data and minimize the risk of error, ensure personal data in such a way that possible risks to the interests and rights of the data subject are taken into account, and prevent, among other things, discriminatory effects on individuals based on race or ethnic origin, political opinions, religion or beliefs, trade union membership, genetic condition or health status or sexual orientation, or processing that results in measures that produce such effects.'" (the emphasis is from the AEPD).

Article 4.15 of the GDPR defines "health-related data" as "personal data related to the physical or mental health of a natural person, including the provision of health care services, which reveal information about their health status."

Recital 35 of the GDPR clarifies this definition by stating that "All personal data related to the health of the data subject that provide information about their past, present, or future physical or mental health status must be included. This includes information about the natural person collected during their registration for health care purposes, or during the provision of such care, in accordance with Directive 2011/24/EU of the European Parliament and of the Council; any number, symbol, or data assigned to a natural person that uniquely identifies them for health purposes; information obtained from tests or examinations of a part of the body or a bodily substance, including that derived from genetic data and biological samples, and any information related, for example, to an illness, a disability, the risk of suffering from diseases, medical history, clinical treatment, or the physiological or biomedical status of the data subject, regardless of its source, for example, a doctor or other health professional, a hospital, a medical device, or an in vitro diagnostic test."

It is worth noting that the Court of Justice of the European Union (CJEU) has established a broad concept of health data. Thus, in accordance with the CJEU ruling of October 4, 2024, in case C 21/23 (the emphasis is from the AEPD):

"76 Among these special categories of personal data, which are listed in Article 8(1) of Directive 95/46 and in Article 9(1),

18/45

of the GDPR, health-related data is included. These include, in accordance with Article 4, point 15, of the Regulation, in relation to its Recital 35, all personal data revealing information about the past, present, or future physical or mental health status of an individual, including data related to the provision of healthcare services to that individual.

81 In this regard, the Court of Justice has already stated that, in light of the objective of Directive 95/46 and the GDPR, to ensure a high level of protection of the freedoms and fundamental rights of individuals, particularly their privacy, in relation to the processing of personal data affecting them, the concept of "health-related data" provided for in Article 9, paragraph 1, of that Regulation and in Article 8, paragraph 1, of the aforementioned Directive must be interpreted broadly (see, in this sense, the judgments of November 6, 2003, *Lindqvist*, C 101/01, EU:C:2003:596, paragraph 50, and August 1, 2022, *Vyriausioji tarnybinės etikos komisija*, C 184/20, EU:C:2022:601, paragraph 125). Furthermore, the same CJEU ruling determines that when the processing of personal data may indirectly reveal sensitive information about a person, such data falls under the regime provided for in Article 9 of the GDPR:

"82 In particular, such provisions should not be interpreted in the sense that the processing of personal data that may indirectly reveal sensitive information about an individual is outside the enhanced protection regime established by the aforementioned provisions, as being excluded would undermine the useful effect of that regime and the protection of the freedoms and fundamental rights of individuals that it aims to guarantee (judgment of August 1, 2022, *Vyriausioji tarnybinės etikos komisija*, C 184/20, EU:C:2022:601, paragraph 127)."

In the same vein, the aforementioned judgment determines that special categories of personal data are subject to the prohibition of Article 9 of the GDPR regardless of whether the information is accurate or not and whether the processing aims to obtain personal data belonging to that category:

"87 This prohibition is independent of whether the information revealed by the processing in question is accurate or not and whether the pharmacist acts with the aim of obtaining information included in any of the special categories provided for in Article 8, paragraph 1, of Directive 95/46 and Article 9, paragraph 1, of the GDPR. Indeed, considering the significant risks to the fundamental freedoms and rights of the data subjects generated by any processing of personal data included in such categories, these provisions aim to prohibit such processing, regardless of the purpose expressed and the accuracy of the information in question [see, in this sense, the judgment of July 4, 2023, *Meta Platforms and others. (General terms of service of a social network)*, C 252/21, EU:C:2023:537, paragraphs 69 and 70]."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sede@aedp.gob.es

19/45

For its part, the Supreme Court ruling of October 8, in the cassation appeal 1920/21, reaffirms the broad concept of health data, stating that:

"(...) it should be emphasized, in this regard, that the reading of Article 4.15 and Recital 35 of the General Data Protection Regulation supports, as the contested ruling of the National Court holds, the inclusion of the notion of 'data related to health' concerning the health status of athletes, since, although the European Union legislation does not contain any specific provision regarding data related to the application of doping control techniques, it broadly defines the processing of health data. Recital 35 of the aforementioned Regulation (EU) 2016/679 specifically includes, among health-related data, all data concerning the health status of the data subject that provides information about their physical or mental health status past, present, or future, including information about the individual collected in connection with their registration for healthcare purposes, or in connection with the provision of such assistance, accordingly."

There is no doubt, therefore, that data regarding the dispensing of medications or diapers by a pharmacy, the CIPA (Autonomous Personal Identification Code), and the health card number are health data, as well as all those that indirectly reveal a person's health status.

In any case, the circumstances that allow for the lifting of the prohibition on the processing of health

data established by Article 9.1 are determined in Article 9.2 of the GDPR. That is to say, it is necessary for one of the premises established in the aforementioned article to be present in order for the processing of health data to be carried out. These exceptions must be interpreted restrictively, as can be inferred from Recitals 51 to 56 of the GDPR.

The dispensing of medications and diapers involves the processing of health data, and the lifting of the prohibition on processing this data will be found in Article 9.2 h); to the extent that the processing is necessary for the provision of healthcare or treatment.

Furthermore, Article 9.3 requires, for the specific premise of Article 9.2 h), that the processing be carried out by a professional subject to the obligation of professional law or under their responsibility. The lifting of the prohibition contained in letter h) of Article 9.2, as well as the additional provisions of Article 9.3 for the use of this premise, requires a norm of EU law or of the Member State that regulates it, which, in the case of Spain, requires that the healthcare or treatment be included in a norm with the rank of law, to the extent that the right to the protection of personal data is a fundamental right. In this sense, the different operations of processing personal data involved in the dispensing of medications and diapers by pharmacies.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeapd.gob.es

20/45

would find its authorization in Law 14/1986, of April 25, General Health Law; Law 16/1997, of April 25, on the Regulation of Pharmacy Office Services; Royal Legislative Decree 1/2015, of July 24, which approves the consolidated text of the Law on guarantees and rational use of medications and health products; as well as in the applicable regional legislation such as, in the case of Catalonia, Law 31/1991, of December 13, on Pharmaceutical Regulation of Catalonia.

Thus, for example, pharmacy offices are obliged, in accordance with Article 86.3 of Royal Legislative Decree 1/2015, of July 24, to "dispense medications requested by both individuals and the National Health System."

IV

Unfulfilled obligation. Article 6 of the GDPR. Lawfulness of processing

The first paragraph of Article 6 of the GDPR establishes the following:

"1. Processing shall be lawful only if at least one of the following conditions is met:

- a) the data subject has given consent to the processing of their personal data for one or more specific purposes;
- b) processing is necessary for the performance of a contract to which the data subject is a party or in order to take steps at the request of the data subject prior to entering into a contract;
- c) processing is necessary for compliance with a legal obligation to which the controller is subject;
- d) processing is necessary to protect the vital interests of the data subject or of another natural person;
- e) processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller;
- f) processing is necessary for the purposes of the legitimate interests pursued by the controller or by a third party, except where such interests are overridden by the interests or fundamental rights and freedoms of the data subject which require protection of personal data, in particular when the data subject is a child.

The provision in point f) of the first paragraph shall not apply to processing carried out by public authorities in the performance of their tasks."

2. Member States may maintain or introduce more specific provisions to adapt the application of the rules of this Regulation regarding processing in compliance with paragraph 1, points c) and e), by specifying more precisely specific processing requirements and other measures that ensure lawful and fair processing, including other specific processing situations under Chapter IX.

3. The basis for processing indicated in paragraph 1, points c) and e), must be established by:

C/ Jorge Juan, 6

a) Union Law, or

b) The law of the Member States that applies to the data controller.

The purpose of the processing must be determined in that legal basis or, in relation to the processing referred to in paragraph 1, letter e), it will be necessary for the performance of a task carried out in the public interest or in the exercise of public powers conferred on the data controller. This legal basis may contain specific provisions to adapt the application of the rules of this Regulation, including, among others: the general conditions governing the lawfulness of processing by the controller; the types of data subject to processing; the affected data subjects; the entities to which personal data may be communicated and the purposes of such communication; the limitation of purpose; the retention periods for the data, as well as the operations and procedures of processing, including measures to ensure lawful and fair processing, such as those relating to other specific processing situations under Chapter IX. Union law or the law of the Member States will fulfill a public interest objective and will be proportional to the legitimate aim pursued.

4. When processing for a purpose other than that for which the personal data were collected is not based on the consent of the data subject or on Union law or the law of the Member States that constitutes a necessary and proportional measure in a democratic society to safeguard the objectives indicated in Article 23, paragraph 1, the data controller, in order to determine whether the processing for another purpose is compatible with the purpose for which the personal data were initially collected, shall take into account, among other things:

a) any relationship between the purposes for which the personal data were collected and the purposes of the intended further processing;

b) the context in which the personal data were collected, in particular with regard to the relationship between the data subjects and the data controller;

c) the nature of the personal data, in particular when special categories of personal data are processed, in accordance with Article 9, or personal data relating to criminal convictions and offenses, in accordance with Article 10;

d) the possible consequences for the data subjects of the intended further processing;

e) the existence of appropriate safeguards, which may include encryption or pseudonymization."

In this regard, Recital 32 of the GDPR states that: "Consent must be given by a clear affirmative act that reflects the data subject's freely given, specific, informed, and unambiguous indication of their wishes to accept the processing of personal data concerning them, such as a written statement, including by electronic means, or a verbal statement. This could include ticking a box on an internet website, choosing technical parameters for the use of information society services, or any other statement or conduct that clearly indicates in this context that the data subject accepts the proposed processing of their personal data. Therefore, silence, pre-ticked boxes, or inactivity should not constitute consent. Consent must be given for all processing activities carried out for the same or the same purposes. When processing has multiple purposes, consent must be given for all of them. If the consent of the data subject is to be given as a result of a request by...

C/ Jorge Juan, 6

electronic means, the request must be clear, concise, and not unnecessarily disturb the use of the service for which it is provided."

In turn, Article 4 of the GDPR, relating to definitions, establishes in paragraph 11:

"11) 'consent of the data subject': any manifestation of free, specific, informed, and unambiguous will by which the data subject accepts, either by a statement or a clear affirmative action, the processing of personal data concerning them;"

On the other hand, Article 24 of the GDPR develops the principle of proactive responsibility of the data controller, requiring that their actions not only comply with the GDPR but also be able to demonstrate it:

"Taking into account the nature, scope, context, and purposes of the processing as well as the risks of varying probability and severity to the rights and freedoms of natural persons, the data controller shall implement appropriate technical and organizational measures to ensure and be able to demonstrate that the processing is in compliance with this Regulation. Such measures shall be reviewed and updated as necessary."

In short, the processing of personal data requires the existence of a legal basis that legitimizes it. The choice of the most appropriate basis for processing, in case there are several, corresponds to the controller, just as it is their responsibility to prove that the processing is carried out in accordance with a legitimizing basis.

In accordance with Article 6.1 of the GDPR, in addition to consent, there are other possible bases that legitimize the processing of data without the need for the authorization of its owner, in particular, when necessary for the performance of a contract in which the data subject is a party or for the application, at their request, of pre-contractual measures, or when necessary for the satisfaction of legitimate interests pursued by the data controller or by a third party, provided that such interests do not override the interests or fundamental rights and freedoms of the data subject requiring the protection of such data. Processing is also considered lawful when necessary for compliance with a legal obligation to which the data controller is subject, to protect vital interests of the data subject or another natural person, or for the performance of a task carried out in the public interest or in the exercise of official authority vested in the data controller.

In the present case, A.A.A. dispenses diapers to residents of geriatric centers, for which it processes the personal data of these individuals.

This is stated in the minutes ***ACTA.1 of the Pharmacy Inspection which indicates: "...", and this has been confirmed by the accused party to this Agency, providing the periods in which these actions were carried out and the number of affected residents, although from their response it is inferred that, when they responded to the information request, they were still providing the diaper dispensing service to two geriatric residences (***RESIDENCIA.4 and ***RESIDENCIA.5).

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sede.aepd.gob.es
23/45

According to the information provided by her on November 4, 2024, the list of residences to which she provides or has provided services is: "****RESIDENCIA.4 from 2019 to present (6 residents), ***RESIDENCIA.5 from June 2024 to present (19 residents), ***RESIDENCIA.2 from 01/20/21 to 04/25/23 (an average of 20 residents), ***RESIDENCIA.6 from 05/10/23 to 11/23/23 (an average of 20 residents)."

The way to access the residents' data was orchestrated through the access keys to the ***PROGRAMA.1 program, which were sent to them by another pharmacy, without prejudice to the fact that this same pharmacy sent them unencrypted emails containing the residents' data (including health data). This is recorded in the aforementioned minutes: "...".

Therefore, from 2019 to the present (or at least until November 4, 2024), A.A.A. has dispensed diapers to different residences for a variable number of affected individuals, totaling 65 people over the entire period. As of today, she continues to dispense diapers for approximately 25 patients.

In this regard, the reported party claims that it acted as the data controller, based on Article 6.1 c), and that the processing was necessary for compliance with a legal obligation.

However, neither the aforementioned legal basis nor that corresponding to the exercise of a public interest mission, recognized in a law, are considered sufficient. As previously noted, the regulatory provisions set forth in the specific sectoral legislation would lift the prohibition on the processing of health data by pharmacies, in accordance with Article 9.2 h), but it cannot be considered that the aforementioned regulatory provisions support the processing by a specific pharmacy to the detriment

of another and that, therefore, they can constitute a legal basis by themselves.

Furthermore, reviewing the different possible legal bases, there is no record of a contract signed between A.A.A. and the affected residents, as holders of the fundamental right.

It is worth noting that the specific sectoral regulations enshrine the principle of freedom of choice of pharmacy by the user or patient, as determined in the Preliminary Questions of this document, which means that the patient or user is free to choose the pharmacy they wish to dispense their medication. That said, in the present case, there is no record of the patients' consent for the processing of their data by A.A.A. for the dispensing of diapers. It is emphasized, however, that in the RAT provided by the reported party in response to the request made by this Agency, it was stated: "in the event that the holder of the pharmacy intends to make use beyond what is provided for by current regulations, they must obtain the consent of the affected party."

Regarding vital interest, Recital 46 of the GDPR establishes the exceptional nature of this legal basis and its uniqueness, stating that personal data should only be processed on this basis when the processing cannot be manifestly based on other grounds.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaeapd.gob.es

24/45

on a different legal basis. It also mentions that certain types of processing may respond to both significant reasons of public interest and the vital interests of the data subject, such as when processing is necessary for humanitarian purposes, including the control of epidemics and their spread, or in situations of humanitarian emergency, especially in the case of natural or human-made disasters.

The consideration of vital interest necessarily refers to the existence of a certain, plausible risk, not simply potential based on general, non-specific data, given the necessity of this specific processing that overrides other legal bases for processing, such as consent.

Finally, the legitimate interest of A.A.A. would require the existence of this interest in the first place, and subsequently, a balancing of it with the rights and freedoms of the affected individuals, something that is not evident in the present case.

In summary, there is no legal basis that supports the processing of the dispensing of medications and diapers carried out by A.A.A. regarding the personal data of the residents of the aforementioned geriatric centers.

Therefore, in accordance with the evidence available at this moment in the initiation of sanctioning procedure, it is considered that the known facts could constitute an infringement attributable to A.A.A. for violation of Article 6 of the GDPR.

V

Classification of the infringement of Article 6.1 of the GDPR and qualification for the purposes of prescription

Article 83.5 of the GDPR classifies the violation of the following article as an administrative infringement, which will be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of a company, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

"a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9;"

For its part, the LOPDGDD in its Article 71, Infringements, states that:

"Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the sole purposes of the prescription period, Article 72.1 of the LOPDGDD establishes the following:

"Based on what is established in Article 83.5 of Regulation (EU) 2016/679, the following are considered very serious and will prescribe in three years:

b) The processing of personal data without any of the conditions for lawful processing established in Article 6 of Regulation (EU) 2016/679."

VI

Proposal for sanction for non-compliance with Article 6 of the GDPR.

In order to determine the administrative fine to be imposed, the provisions of Articles 83.1 and 83.2 of the GDPR must be observed, which state:

"1. Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation indicated in paragraphs 4, 9, and 6 are, in each individual case, effective, proportionate, and dissuasive.

2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those provided for in Article 58, paragraph 2, letters a) to h) and j). In deciding on the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

- a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of affected data subjects and the level of damage and harm suffered;
- b) the intentionality or negligence in the infringement;
- c) any measures taken by the controller or processor to mitigate the damage and harm suffered by the data subjects;
- d) the degree of responsibility of the controller or processor, taking into account the technical or organizational measures they have implemented pursuant to Articles 25 and 32;
- e) any previous infringement committed by the controller or processor;
- f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;
- g) the categories of personal data affected by the infringement;
- h) the manner in which the supervisory authority became aware of the infringement, in particular whether the controller or processor notified the infringement and, if so, to what extent;
- i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the controller or processor in relation to the same matter, compliance with those measures;
- j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42, and
- k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement."

For its part, Article 76 "Sanctions and corrective measures" of the LOPDGDD provides:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeae@pd.gob.es

26/45

"1. The sanctions provided for in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679 shall be applied taking into account the criteria for graduation established in paragraph 2 of the aforementioned article.

2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

- a) The continued nature of the infringement.
- b) The link between the infringer's activity and the processing of personal data.
- c) The benefits obtained as a result of the commission of the infringement.
- d) The possibility that the conduct of the affected party may have induced the commission of the infringement.
- e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.
- f) The impact on the rights of minors.

g) Having, when not mandatory, a data protection officer.

h) The voluntary submission by the controller or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any interested party.”

In the present case, considering the seriousness of the possible infringement, particularly regarding the consequences that its commission causes to the affected parties, it would be appropriate to impose a fine, in addition to adopting measures, if applicable.

The fine imposed must be, in each individual case, effective, proportionate, and dissuasive, in accordance with the provisions of Article 83.1 of the GDPR.

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment of the initiation of the sanctioning procedure, and without prejudice to what results from the instruction, it is considered appropriate to graduate the sanction to be imposed according to the following circumstances, contemplated in the aforementioned provisions.

- The nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of affected parties and the level of damage and harm they have suffered (Article 83.2(a) of the GDPR): the alleged facts negatively impact the control of the affected parties over their personal data, with control over personal data being a fundamental element and the backbone of the GDPR. Ultimately, the actions carried out by A.A.A. imply the loss of control and disposition of the data concerning the holder of the fundamental right. In this regard, the number of affected parties and residences involved cannot be overlooked, which gives the infringement "systemic" connotations, even though the number of affected parties has varied over time. In total, from 2019 to the present, there would be 65 affected residents.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaeapd.gob.es

27/45

Lastly, it is noted that the failure to demonstrate the existence of a legitimate basis for processing constitutes a violation of the principle of proactive responsibility provided for in Article 5.2 of the GDPR, which is an essential principle of data protection regulation.

-

The intent or negligence in the infringement (Article 83.2(b)): serious negligence is observed to the extent that the processing of health data is carried out in violation of specific sectoral regulations, based on the free choice of pharmacy by patients, as well as the Code of Ethics of the pharmaceutical profession approved by the General Council of Pharmaceutical Colleges, which establishes that “any action in the field of health that has a patient or user as its recipient requires their informed, free, and voluntary consent. The pharmacist must respect their decision, as established in the legislation.”

-

The categories of personal data affected by the infringements (Article 83.2(g) of the GDPR): the Guidelines 04/2022 of the European Data Protection Board, regarding the calculation of fines under the GDPR, adopted on May 24, 2023, in their section 57, state the following regarding the requirement to take into account the categories of affected personal data: “(...) the GDPR clearly highlights the types of data that deserve special protection and, therefore, a stricter response regarding fines. This refers, at a minimum, to the types of data referred to in Articles 9 and 10 of the GDPR and to data outside the scope of these articles whose dissemination causes immediate harm to the data subject (for example, location data, data about private communication, national identification numbers, or financial data, such as transaction summaries or credit card numbers).” In the present case, the personal data being processed includes health data, such as, for example, the medical regimen of the affected individuals or the health card number or CIPA.

Furthermore, the following aggravating factors are considered:

-

The link between the infringer's activity and the processing of personal data (Article 83.2(k) of the GDPR in connection with Article 76.2(b) of the LOPDGDD): the pharmacy A.A.A., as a result of its activity as a private healthcare establishment of public interest, regularly and continuously processes

personal data of a large number of data subjects (all its patients or users), which is essential for the development of its business. The dispensing of medical and pharmaceutical products, which is its main activity, necessarily involves operations of personal data processing. Thus, the infringing actions occur within the framework of personal data processing that A.A.A. routinely carries out in its business and related to it.

-

The benefits obtained as a result of the commission of the infringement (Article 83.2(k) of the GDPR in connection with Article 76.2(c) of the LOPDGDD): the dispensing of pharmaceutical products for patients of

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaeapd.gob.es

28/45

Different residences without a basis for legitimacy imply that pharmacy A.A.A. has provided a service (supply of diapers) in exchange for economic compensation. Ultimately, the pharmacy has profited from the actions that constitute the infringement.

The balance of the circumstances contemplated in Article 83.2 of the GDPR and 76.2 of the LOPDGDD, regarding the infringement committed by violating the provisions of Article 6.1 of the GDPR, allows for the initial determination, and without prejudice to what results from the instruction of this sanctioning procedure, an administrative fine of €5,000.

VII

Unfulfilled obligation. Article 14 of the GDPR. Information to be provided when personal data has not been obtained from the data subject

According to the provisions of Article 14 of the GDPR:

"1. When personal data has not been obtained from the data subject, the data controller shall provide the following information:

- a) the identity and contact details of the controller and, where applicable, of its representative;
- b) the contact details of the data protection officer, where applicable;
- c) the purposes of the processing for which the personal data are intended, as well as the legal basis for the processing;
- d) the categories of personal data concerned;
- e) the recipients or categories of recipients of the personal data, where applicable;
- f) where applicable, the intention of the controller to transfer personal data to a recipient in a third country or an international organization and the existence or absence of an adequacy decision by the Commission, or, in the case of transfers referred to in Articles 46 or 47 or Article 49, paragraph 1, second subparagraph, reference to the appropriate or suitable safeguards and the means to obtain a copy thereof or the place where they have been made available.

2. In addition to the information mentioned in paragraph 1, the data controller shall provide the data subject with the following information necessary to ensure fair and transparent data processing with respect to the data subject:

- a) the period for which the personal data will be stored or, when that is not possible, the criteria used to determine that period;
- b) when the processing is based on Article 6, paragraph 1, letter f), the legitimate interests of the data controller or a third party;
- c) the existence of the right to request from the data controller access to personal data concerning the data subject, and its rectification or erasure, or the restriction of processing, and to object to the processing, as well as the right to data portability;
- d) when the processing is based on Article 6, paragraph 1, letter a), or Article 9, paragraph 2, letter a), the existence of the right to withdraw consent at any time, without affecting the lawfulness of the processing based on the consent before its withdrawal;

C/ Jorge Juan, 6

- e) the right to lodge a complaint with a supervisory authority;
- f) the source from which the personal data originates and, where applicable, whether it comes from publicly accessible sources;
- g) the existence of automated decision-making, including profiling, referred to in Article 22, paragraphs 1 and 4, and, at least in such cases, significant information about the logic involved, as well as the significance and the expected consequences of such processing for the data subject.

3. The data controller shall provide the information indicated in paragraphs 1 and 2:

- a) within a reasonable timeframe, once the personal data has been obtained, and at the latest within one month, taking into account the specific circumstances in which the data is processed;
- b) if the personal data is to be used for communication with the data subject, at the latest at the time of the first communication to that data subject, or
- c) if it is intended to communicate them to another recipient, at the latest at the time the personal data is communicated for the first time.

4. When the data controller intends to further process the personal data for a purpose other than that for which it was obtained, they shall provide the data subject, prior to such further processing, information about that other purpose and any other pertinent information indicated in paragraph 2.

5. The provisions of paragraphs 1 to 4 shall not apply when and to the extent that:

- a) the data subject already has the information;
- b) the communication of such information proves impossible or would involve a disproportionate effort, in particular for processing for archiving purposes in the public interest, for scientific or historical research purposes, or for statistical purposes, subject to the conditions and safeguards referred to in Article 89, paragraph 1, or to the extent that the obligation mentioned in paragraph 1 of this article may prevent or seriously hinder the achievement of the objectives of such processing. In such cases, the controller shall take appropriate measures to protect the rights, freedoms, and legitimate interests of the data subject, including making the information public;
- c) obtaining or communicating it is expressly laid down by Union or Member State law applicable to the data controller and which provides for adequate measures to protect the legitimate interests of the data subject, or
- d) when the personal data must continue to be kept confidential based on a professional secrecy obligation regulated by Union or Member State law, including a legal obligation of secrecy.

When personal data relating to a person is obtained, and it has not been obtained directly from them, the data controller must provide them with all the information regarding the processing of their data as indicated in Article 14 of the GDPR. The GDPR requires that this information be provided as soon as possible and, in any case, no later than one month, or in the event that a communication must be made to them, no later than at the time of that first communication or at the time when it is to be communicated to another recipient, at the latest. In this regard, Recital 61 states:

61) "Interested parties must be provided with information about the processing of their personal data at the time it is obtained from them or, if obtained from another source, within a reasonable period, depending on the circumstances of the case. If the personal data can legitimately be communicated to another recipient, the interested party must be informed at the time it is communicated to the recipient for the first time. The data controller intending to process the data for a purpose other than that for which it was collected must provide the interested party, prior to such further processing, with information about that other purpose and any other necessary information. When the source of the personal data cannot be provided to the interested party due to multiple sources being used, general

information must be provided."

It is important to highlight that the obligation to inform in Article 14 of the GDPR must be understood within the framework of the rights of the interested parties concerning transparency, a principle that must govern the processing of data in accordance with Article 5.1 a) of the GDPR. In this regard, Article 12.1 of the GDPR states that:

"(...) The data controller shall take appropriate measures to provide the interested party with all information referred to in Articles 13 and 14 (...) in a concise, transparent, intelligible, and easily accessible form, using clear and plain language (...)"

In this respect, it is essential to refer to Recital 39 of the GDPR, which establishes that:

"(39) All processing of personal data must be lawful and fair. For natural persons, it must be completely clear that personal data concerning them is being collected, used, consulted, or otherwise processed, as well as the extent to which such data is or will be processed. The principle of transparency requires that all information and communication relating to the processing of such data be easily accessible and easy to understand, and that clear and plain language be used. This principle particularly refers to the information provided to the interested parties about the identity of the data controller and the purposes of the processing, as well as additional information to ensure fair and transparent processing concerning the affected natural persons and their right to obtain confirmation and communication of the personal data concerning them that is being processed. Natural persons must be aware of the risks, rules, safeguards, and rights related to the processing of personal data, as well as how to exercise their rights in relation to the processing. In particular, the specific purposes of the processing of personal data must be explicit and legitimate, and must be determined at the time of collection. Personal data must be adequate, relevant, and limited to what is necessary for the purposes for which they are processed. This requires, in particular, ensuring that their retention period is limited to a strict minimum. Personal data should only be processed if the purpose of the processing cannot reasonably be achieved by other means. To ensure that personal data is not kept longer than necessary, the data controller must establish deadlines for its deletion or periodic review."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sede.aepd.gob.es
31/45

All reasonable measures must be taken to ensure that inaccurate personal data is rectified or deleted. Personal data must be processed in a manner that ensures adequate security and confidentiality of personal data, including to prevent unauthorized access or use of such data and the equipment used in the processing.

In addition to what is established in Recital 60, which states:

60) "(...) The principles of fair and transparent processing require that the data subject be informed of the existence of the processing operation and its purposes. The data controller must provide the data subject with any additional information necessary to ensure fair and transparent processing, taking into account the specific circumstances and context in which the personal data are processed (...)"

In the present case, the personal data of the residents was provided to A.A.A. by Pharmacy B.B.B.

According to what was stated in the response to the Pharmacy Inspection and to this Agency.

There is no documentation that proves that A.A.A. provided the affected individuals, whose personal data it processed for the purpose of dispensing diapers, with any information regarding any of the elements contained in Article 14 of the GDPR. It is also not documented that such information was provided to those whose data it continues to process.

In fact, in the response regarding this specific aspect to this Agency during the preliminary investigation proceedings, the responsible party merely stated that "we had no contact with the residents. All the information was received through the intermediary pharmacy."

At all times, A.A.A. acknowledges its status as the data controller, which, in accordance with Article 14 of the GDPR, obliges it to transmit to the data subjects all the information contained in the aforementioned article within the specified timeframes. None of this has been substantiated by the

responsible party.

Therefore, in accordance with the evidence available at this moment of the initiation of the sanctioning procedure, it is considered that the known facts could constitute an infringement, attributable to Pharmacy A.A.A. for violation of Article 14 of the GDPR as previously transcribed.

VIII

Classification of the infringement of Article 14 of the GDPR and qualification for the purposes of prescription

Article 83.5 of the GDPR classifies the violation of the following article as an administrative infringement, which will be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

"b) the rights of the data subjects under Articles 12 to 22;"

For its part, the LOPDGDD in its Article 71, Infringements, states:

"Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the sole purpose of the prescription period, Article 72.1 of the LOPDGDD establishes the following:

"Based on what is established in Article 83.5 of Regulation (EU) 2016/679, the following infringements are considered very serious and will prescribe in three years, which involve a substantial violation of the articles mentioned therein and, in particular, the following:

h) The omission of the duty to inform the affected party about the processing of their personal data in accordance with the provisions of Articles 13 and 14 of Regulation (EU) 2016/679 and 12 of this organic law."

IX

Proposal for sanction for non-compliance with Article 14 of the GDPR.

In order to determine the administrative fine to be imposed, the provisions of Articles 83.1 and 83.2 of the GDPR, and 76 LOPDGDD, previously reproduced, must be observed.

In the present case, considering the seriousness of the possible infringement, especially regarding the consequences that its commission causes to the affected individuals, the imposition of a fine, in addition to the adoption of measures, if appropriate, would be warranted.

The fine imposed must be, in each individual case, effective, proportionate, and dissuasive, in accordance with what is established in Article 83.1 of the GDPR.

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment of the initiation of the sanctioning procedure, and without prejudice to what results from the instruction, it is considered appropriate to grade the sanction to be imposed according to the following circumstances, contemplated in the aforementioned provisions:

- The nature, gravity, and duration of the infringement (Article 83.2 letter a), of the GDPR): it is highlighted that in this case no type of information was provided to the residents (not even the most basic such as who and for what the data is used), when the information provided to the data subject by a controller is essential for them to be aware of

33/45

the existence of a treatment and its purposes, among other aspects, allowing for genuine control over their data, including the possibility for the data subject not to provide it. In this regard, it is necessary to highlight the duration of the infringement, which continues to this day, notwithstanding that it began in 2019.

-

The intentionality or negligence in the infringement (Article 83.2(b)): serious negligence is evident to the extent that the lack of information occurs in violation of the Code of Ethics of the pharmaceutical profession approved by the General Council of Pharmaceutical Colleges, which establishes that "the pharmacist must provide information to the patient/user in an objective, updated, simple manner, and appropriate to the understanding capabilities of the person being attended to, and must do so in writing if requested." Furthermore, it is determined that "patients and users have the right to know the identity and qualifications of the professional attending to them."

-

The categories of personal data affected by the infringements (Article 83.2(g) of the GDPR): the Guidelines 04/2022 of the European Data Protection Board, regarding the calculation of fines under the GDPR, adopted on May 24, 2023, in its section 57, state the following regarding the requirement to take into account the categories of personal data affected: "(...) the GDPR clearly highlights the types of data that deserve special protection and, therefore, a stricter response regarding fines. This refers, at a minimum, to the types of data referred to in Articles 9 and 10 of the GDPR and to data outside the scope of these articles whose dissemination causes immediate harm to the data subject (for example, location data, data on private communication, national identification numbers, or financial data, such as transaction summaries or credit card numbers)." In the present case, the personal data subject to processing includes health data, such as, for example, the medical regimen of the affected individuals or the health card or CIPA number.

Furthermore, the following aggravating factors are considered:

-

The link between the infringer's activity and the processing of personal data (Article 83.2(k) of the GDPR in connection with Article 76.2(b) of the LOPDGDD): the pharmacy, as a result of its activity as a private healthcare establishment of public interest, regularly and continuously processes personal data of a large number of data subjects (all its patients or users), which is essential for the development of its business. The performance of activities related to the dispensing of medical and pharmaceutical products, which is its main activity, necessarily involves operations for the processing of personal data. Thus, the infringing actions occur within the framework of a processing of personal data that the pharmacy routinely carries out in its business and related to it.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeapd.gob.es

34/45

For the purposes of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment of the initiation of the sanctioning procedure, and without prejudice to what results from the instruction, it is considered that the balance of the circumstances contemplated in Article 83.2 of the GDPR and 76.2 of the LOPDGDD, regarding the infringement committed by violating the provisions of Article 14 of the GDPR, allows for the initial setting of an administrative fine of €3,000.00 (THREE THOUSAND EUROS).

X

Obligation not fulfilled. Article 32 of the GDPR. Security of processing.

Article 32 of the GDPR establishes:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
 - b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
 - c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
 - d) a process for regularly testing, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.
2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the data processing, in particular as a result of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.
3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the

requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data only processes such data on instructions from the controller, unless required to do so by Union or Member State law.”

The obligation to adopt all technical and organizational measures imposed by Article 32 of the GDPR on the data controller is a manifestation of the two essential pillars of the GDPR: the proactive accountability enshrined in Article 5.2 and developed in Article 24.1 of the GDPR and the risk-based approach. Thus, Article 32, while establishing a set of measures that could be considered minimal to be adopted by the controller, such as pseudonymization or data encryption, cannot in any case be understood as a *numerus clausus* since these must address the nature, scope, context, and purposes of the processing, as well as the risks of likelihood and severity affecting personal data.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeae@pd.gob.es

35/45

As can be observed, there has been a shift from a reactive system to a proactive one, based on prevention rather than correction, which must operate throughout the entire lifecycle of personal data, not only during collection. In this regard, Recital 74 of the GDPR states (the underlining is from the AEPD):

“74 The responsibility of the data controller must be established for any processing of personal data carried out by them or on their behalf. In particular, the controller must be obliged to implement appropriate and effective measures and must be able to demonstrate compliance of the processing activities with this Regulation, including the effectiveness of the measures. Such measures must take into account the nature, scope, context, and purposes of the processing, as well as the risk to the rights and freedoms of natural persons.”

For its part, Recital 75 determines:

“(75) The risks to the rights and freedoms of natural persons, of varying severity and probability, may arise from the processing of data that could cause physical, material, or immaterial harm, particularly in cases where the processing could lead to issues of discrimination, identity theft or fraud, financial losses, damage to reputation, loss of confidentiality of data subject to professional secrecy, unauthorized reversal of pseudonymization, or any other significant economic or social harm; in cases where individuals are deprived of their rights and freedoms or prevented from exercising control over their personal data; in cases where the personal data processed reveal ethnic or racial origin, political opinions, religion or philosophical beliefs, trade union membership, and the processing of genetic data, health data, or data concerning sexual life, or criminal convictions and related security measures; in cases where personal aspects are evaluated, in particular the analysis or prediction of aspects related to work performance, economic situation, health, personal preferences or interests, reliability or behavior, situation or movements, in order to create or use personal profiles; in cases where personal data of vulnerable persons, particularly children, are processed; or in cases where the processing involves a large amount of personal data and affects a large number of individuals.”

In the present case, the pharmacy, as a private healthcare establishment with public interest, predominantly carries out processing of particularly sensitive data, such as health data. This circumstance must be taken into account when establishing appropriate security measures relative to the risk.

The risk-based approach to data protection involves adopting and implementing measures aimed at protecting the confidentiality, availability, and integrity of personal data, where the risk to rights and freedoms acts as a switch or modulator for the measures to be adopted.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeae@pd.gob.es

In this regard, the CJEU ruling of December 14, 2023, *Natsionalna agentsia za prihodite*, case C-340/21, EU:C:2023:986 states:

“[the adoption of security measures regarding the protection of personal data] is not fulfilled by the adoption of any measure, as they must be necessary to ensure the objectives set by the provision, and of course, it is not enough to have the formal approval of security measures, as it is required that they be established and effectively implemented in practice. We have therefore considered that there is an obligation of result, consisting of adopting the necessary measures to prevent data from being lost, misplaced, or ending up in the hands of third parties. Ultimately, every data controller (or data processor) is, by legal provision, a debtor of security regarding data, and must ensure that such measures or mechanisms are effectively implemented in practice.”

In the present case, there are elements that would indicate that the reported party lacked the appropriate technical and organizational measures relative to the level of risk to ensure the protection of the personal data of the treated residents, especially their confidentiality.

According to the record ***ACTA.1 of the Pharmacy Inspection, the exchange of personal data was routinely carried out by sending files containing health data via unencrypted emails “(...)”.

That is to say, from the account ***EMAIL.1 and without encryption, personal data of patients requiring diapers was sent to A.A.A. in Excel sheets, including health data, and subsequently, the reported party sent an email to the aforementioned account, with the monetary contribution list of the residents, which was later paid from the other pharmacy.

It is noted that regarding this means of exchanging personal data, there are at least two emails in the file that demonstrate the absence of encryption, collected by the Pharmacy Inspection:

An email dated 11/16/2023 containing an exchange of emails between the email address ***EMAIL.1 and ***EMAIL.2 in which an Excel document named “***EXCEL.1” is attached, containing the names and surnames of the residents of the residence ***RESIDENCIA.3 who have diapers available that week.

An email dated 11/17/2023 sent from the email account ***EMAIL.2 to the email address ***EMAIL.1 and copied to ***EMAIL.4 with the text: “Attached are sales and contributions from November 17.” The email includes an attached Excel document named “***EXCEL.2” which contains, among other information, the names and surnames of residents of ***RESIDENCIA.3.

This demonstrates that A.A.A. lacked a secure system for sending and receiving personal data of patients in residences. Thus, the channel of

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeaeapd.gob.es

The communication established for the exchange of information and personal data between both pharmacies lacked adequate security measures commensurate with the risk. It is also highlighted that these practices contravene the provisions set forth in the RAT of the reported party, submitted to this Agency in response to the information request during the preliminary investigation proceedings, which stated: “(...) high-level technical and organizational security measures must be adopted (...)”.

Regarding the security of email, the “Best Practices Report” of May 2021, CNN-CERT BP02, from the National Cryptologic Center, a service attached to the National Intelligence Center, whose mission is to contribute to the improvement of Spanish cybersecurity, outlines a series of vulnerabilities of email and the various ways in which they can be attacked, as well as security recommendations. In section 4.2 of this Report, the “Security of email communications” is described, with the following assertions on pages 37 to 39:

“The protocol involved in this sending process is SMTP. This protocol has been used since 1982, and when it was implemented, security measures such as encryption or authentication of communications were not taken into account. This means that the entire sending process described above would be carried out in plain text, meaning that at any point in the transmission, an attacker could view and manipulate the content of the emails. Due to these shortcomings in SMTP, various technologies and

extensions have been developed that allow for the incorporation of security measures to ensure authentication, integrity, and encryption of email communications. Some of the most well-known technologies are STARTTLS, SPF, DKIM, and DMARC... Although well-known email providers such as Google, Yahoo, and Outlook encrypt and authenticate emails using these types of technologies, many organizations continue to use email carelessly. It should also be noted that these technologies must be implemented both at the source and at the destination for them to be utilized. Furthermore, some of these measures are susceptible to being attacked. For example, STARTTLS is vulnerable to downgrade attacks, where an attacker in a man-in-the-middle situation can force the TLS negotiation not to take place (it would be enough to replace the STARTTLS string).

Even if the TLS communication is successfully established, the mail servers through which the email passes until it reaches its destination would have access to its content. Due to these facts, it is concluded that it is not sufficient to delegate the security of email to the underlying technologies responsible for delivering it to its recipient.”

Therefore, in accordance with the evidence available at this moment in the initiation agreement of the sanctioning procedure, it is considered that the known facts could constitute an infringement attributable to A.A.A., for violation of Article 32 of the GDPR transcribed above.

XI

Classification of the infringement of Article 32 of the GDPR and qualification for the purposes of prescription

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeae@aedp.gob.es

38/45

If confirmed, the aforementioned infringement of Article 32 of the GDPR could imply the commission of the infringements classified in Article 83.4 of the GDPR, which states:

“Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to 2% at most of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)”

In this regard, the LOPDGDD, in its Article 71, establishes that: “Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements.”

For the purposes of the statute of limitations, Article 73 “Infringements considered serious” of the LOPDGDD indicates:

“According to what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and shall prescribe after two years: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security appropriate to the risk of processing, as required by Article 32.1 of Regulation (EU) 2016/679.”

XII

Proposal for sanction for non-compliance with Article 32 of the GDPR.

In order to determine the administrative fine to be imposed, the provisions of Articles 83.1 and 83.2 of the GDPR and Article 76 of the LOPDGDD, previously cited, must be observed.

In the present case, considering the seriousness of the possible infringement, especially regarding the consequences that its commission causes to the affected parties, the imposition of a fine, in addition to the adoption of measures, if appropriate, would correspond.

The fine imposed must be, in each individual case, effective, proportionate, and deterrent, in accordance with the provisions of Article 83.1 of the GDPR.

For the purposes of deciding on the imposition of an administrative fine and its amount, in accordance

with the evidence available at this moment in the initiation agreement of the sanctioning procedure, and without prejudice to what results from the

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeae pd.gob.es
39/45

instruction, it is considered appropriate to adjust the sanction to be imposed in accordance with the following circumstances, as contemplated in the aforementioned provisions.

- The categories of personal data affected by the infringements (Article 83.2, letter g), of the GDPR): the Guidelines 04/2022 of the European Data Protection Board, regarding the calculation of fines under the GDPR, adopted on May 24, 2023, in section 57, state the following regarding the requirement to take into account the categories of personal data affected: "(...) the GDPR clearly highlights the types of data that deserve special protection and, therefore, a stricter response regarding fines. This refers, at a minimum, to the types of data referred to in Articles 9 and 10 of the GDPR and to data outside the scope of these articles whose dissemination causes immediate harm to the data subject (for example, location data, data about private communication, national identification numbers, or financial data, such as transaction summaries or credit card numbers)." In this case, the personal data being processed includes health data, such as, for example, the medical history of the affected individuals or the health card number or CIPA, without prejudice to the fact that the CJEU has established a broad concept of health data.

Furthermore, the following aggravating factors are considered for the adjustment:

- The link of the infringer's activity with the processing of personal data (Article 83.2 k) of the GDPR in connection with Article 76.2, letter b), of the LOPDGDD): A.A.A., as a result of its activity as a private healthcare establishment of public interest, regularly and continuously processes personal data of a large number of data subjects (all its patients or users) essential for the development of its business. The carrying out of activities related to the dispensing of medical and pharmaceutical products, which is its main activity, necessarily involves operations of personal data processing. Thus, the infringing actions occur within the framework of a personal data processing that the pharmacy regularly conducts in its business and linked to it. In accordance with the transcribed provisions, and without prejudice to the outcome of the instruction of the procedure, the initial assessment of the amount of the fine is €3,000.00 (THREE THOUSAND EUROS), for the infringement of Article 32 of the GDPR.

XIII

Corrective Measures

If the infringement is confirmed, the resolution issued may establish the corrective measures that the infringing entity must adopt to put an end to the non-compliance with personal data protection legislation, in this case, Articles 9 and 28 of the GDPR, in accordance with the provisions of the aforementioned Article 58.2.d) of the GDPR, according to which each supervisory authority may "order the controller or processor...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeae pd.gob.es
40/45

of the treatment that the processing operations comply with the provisions of this Regulation, when appropriate, in a specific manner and within a specified timeframe..."

Thus, the responsible entity may be required to adjust its actions to the personal data protection regulations, to the extent expressed in the previous Legal Grounds.

In this act, the presumed infringement committed and the facts that could lead to this possible violation of the data protection regulations are established, from which it is clearly inferred what measures are to be adopted, without prejudice to the fact that the type of procedures, mechanisms, or specific instruments for implementing them corresponds to the sanctioned party, as it is the data controller who fully knows its organization and must decide, based on proactive responsibility and a risk-based

approach, how to comply with the GDPR and the LOPDGDD.

However, in this case, regardless of the above, in accordance with the evidence available at this moment in the initiation agreement of the sanctioning procedure, the resolution adopted may require A.A.A. to adopt the following measures within a period of 3 months from the date of effectiveness of the resolution concluding this procedure:

- Certify the cessation of the processing of personal data for the provision of diapers to the residents of the geriatric centers ***RESIDENCIA.4 and ***RESIDENCIA.5, as well as the deletion of the aforementioned personal data, unless it certifies the existence of a legal basis for such processing.
- Certify, in case of having a legal basis that supports the processing of their personal data, the provision of the information contained in Article 14 of the GDPR to the residents of the geriatric centers ***RESIDENCIA.4 and ***RESIDENCIA.5.

The imposition of these measures is compatible with the sanction consisting of an administrative fine, as provided in Article 83.2 of the GDPR.

It is warned that failure to comply with the possible order to adopt measures imposed by this body in the resolution of the present sanctioning procedure may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in its Articles 83.5 and 83.6, which may motivate such conduct to open a further administrative sanctioning procedure.

It is also reminded that neither the acknowledgment of the infringement committed nor, where applicable, the voluntary payment of the proposed amounts, exempts from the obligation to adopt the necessary measures to cease the conduct or correct the effects of the infringement committed and to certify before this AEPD compliance with that obligation.

Therefore, in light of the above, by the Presidency of the Spanish Agency for Data Protection, IT IS AGREED:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sede.aepd.gob.es

41/45

FIRST: TO INITIATE SANCTIONING PROCEDURE against A.A.A., with NIF ***NIF.1, for:

- A presumed infringement of Article 6 of the GDPR classified in Article 83.5.a) of the GDPR.
- A presumed infringement of Article 14 of the GDPR, classified in Article 83.5.h) of the GDPR.
- A presumed infringement of Article 32 of the GDPR, classified in Article 83.4.a) of the GDPR.

SECOND: TO APPOINT R.R.R. as the instructor and S.S.S. as the secretary, indicating that they may be challenged, if applicable, in accordance with the provisions of Articles 23 and 24 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector (LRJSP).

THIRD: TO INCORPORATE into the file, for evidentiary purposes, as well as the documents obtained and generated by the General Subdirectorate of Data Inspection in the actions prior to the initiation of this sanctioning procedure.

FOURTH: THAT for the purposes provided in Article 64.2 b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the sanction that may correspond would be an administrative fine of:

- For the presumed infringement of Article 6 of the GDPR, an administrative fine of 5,000 euros.
- For the presumed infringement of Article 14 of the GDPR, an administrative fine of 3,000 euros.
- For the presumed infringement of Article 32 of the GDPR, an administrative fine of 3,000 euros.

The above amounts to a total of 11,000 euros, without prejudice to what results from the instruction.

FIFTH: TO NOTIFY this agreement to A.A.A., with NIF ***NIF.1, granting a hearing period of ten working days for them to make allegations and present any evidence they deem appropriate. In their written allegations, they must provide their NIF and the procedure number that appears in the heading of this document.

In accordance with the provisions of Article 85 of the LPACAP, they may acknowledge their responsibility within the period granted for making allegations to this initiation agreement; this will entail a reduction of 20% of the sanction that may be imposed in this procedure. With the application of this

reduction, the sanction would be set at 8,800 euros, concluding the procedure with the imposition of this sanction.

Similarly, they may, at any time prior to the resolution of this procedure, voluntarily pay the proposed sanction, which will entail a reduction of 20% of its amount. With the application of this reduction,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeapd.gob.es

42/45

The penalty will be set at €8,800, and its payment will imply the termination of the procedure, without prejudice to the imposition of the corresponding measures.

The reduction for the voluntary payment of the penalty is cumulative with the one corresponding to the acknowledgment of responsibility, provided that this acknowledgment of responsibility is made within the period granted to submit allegations regarding the opening of the procedure. The voluntary payment of the amount referred to in the previous paragraph may be made at any time prior to the resolution. In this case, if both reductions are applicable, the amount of the penalty will be set at €6,600.

In any case, the effectiveness of either of the two mentioned reductions will be conditioned upon the withdrawal or waiver of any action or administrative appeal against the penalty.

In the event that you choose to proceed with the voluntary payment of either of the amounts indicated above (€8,800 or €6,600), you must make it effective by depositing it into account No. IBAN:

ES00-0000-0000-0000-0000 (BIC/SWIFT Code: CAIXESBBXXX) opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A., indicating in the concept the reference number of the procedure that appears in the heading of this document and the reason for the reduction of the amount to which you are adhering.

You must also send the proof of payment to the General Inspection Sub-Directorate along with the express communication of the withdrawal or waiver of any action or administrative appeal against the penalty to continue with the procedure in accordance with the amount deposited.

Finally, it is noted that according to the provisions of Article 112.1 of the LPACAP, no administrative appeal can be made against this act.

1479-130325

Lorenzo Cotino Hueso

President of the Spanish Agency for Data Protection

>>

SECOND: On April 16, 2025, A.A.A. proceeded to pay the penalty in the amount of €6,600.00, making use of the two reductions provided for in the previously transcribed initiation agreement, which implies the acknowledgment of responsibility concerning the facts referred to in the initiation agreement and its legal qualification.

THIRD: The initiation agreement transcribed above indicated that, if the infringement were confirmed, it could be agreed to impose on the responsible party the adoption of appropriate measures to adjust their actions to the regulations mentioned in this act, in accordance with the provisions of the aforementioned Article 58.2 d) of the GDPR, according to which each supervisory authority may “order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specific manner and within a specified period...”.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeapd.gob.es

43/45

Having acknowledged the responsibility for the infringement, the imposition of the measures included in the initiation agreement is appropriate.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter, LOPDGDD), the Presidency of the Spanish Agency for Data Protection is competent to resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Agency for Data Protection will be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, to the extent that they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Termination of the procedure

Article 85 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), under the heading "Termination in sanctioning procedures" provides the following:

"1. Once a sanctioning procedure has been initiated, if the offender acknowledges their responsibility, the procedure may be resolved with the imposition of the appropriate penalty.

2. When the penalty is solely pecuniary or when a pecuniary penalty and another non-pecuniary penalty can be imposed, but the imposition of the latter has been justified as inappropriate, voluntary payment by the alleged responsible party, at any time prior to the resolution, will imply the termination of the procedure, except regarding the restoration of the altered situation or the determination of compensation for the damages caused by the commission of the infringement.

3. In both cases, when the penalty is solely pecuniary, the competent authority to resolve the procedure will apply reductions of at least 20% on the amount of the proposed penalty, which will be cumulative. The aforementioned reductions must be specified in the notification of initiation of the procedure, and their effectiveness will be conditioned upon the withdrawal or waiver of any action or administrative appeal against the penalty. The percentage of reduction provided for in this section may be increased by regulation."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeae@pd.gob.es

44/45

III

Voluntary Payment and Acknowledgment of Responsibility

In accordance with the provisions of the aforementioned Article 85 of the LPACAP, the notified initiation agreement informed about the possibility of acknowledging responsibility and making a voluntary payment of the proposed sanction, which would entail two cumulative reductions of 20% each. With the application of these two reductions, the sanction would be set at €6,600.00, and its payment would imply the termination of the procedure, without prejudice to the imposition of the corresponding measures.

Following the notification of the aforementioned initiation agreement, A.A.A. has proceeded to acknowledge responsibility and make a voluntary payment of the sanction, availing itself of the two reductions provided. In accordance with paragraph 3 of Article 85 LPACAP, the effectiveness of the aforementioned reductions will be conditioned upon the withdrawal or renunciation of any action or appeal in the administrative pathway against the sanction.

It should be noted that, according to the provisions of the LPACAP, as well as the jurisprudence of the Supreme Court in this matter, the exercise of voluntary payment by the alleged responsible party does not exempt the administration from the obligation to resolve and notify all procedures, regardless of their initiation form. Likewise, Article 88 of the aforementioned regulation establishes that the resolution that concludes the procedure will decide all issues raised by the interested parties and any others arising from it.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of sanctions, the Presidency of the Spanish Agency for Data Protection RESOLVES: FIRST: TO DECLARE the commission of the infringements and TO CONFIRM the sanctions determined in the dispositive part of the initiation agreement transcribed in this resolution. The sum of the aforementioned amounts yields a total of €11,000.00.

After A.A.A. has proceeded with the prompt payment and acknowledgment of responsibility, it is hereby resolved, pursuant to Article 85 of the LPACAP, to reduce the total mentioned by 40%, which results in the final amount of €6,600.00.

The effectiveness of the aforementioned reductions is, in any case, conditioned upon the withdrawal or renunciation of any action or appeal in the administrative pathway.

SECOND: TO DECLARE the termination of procedure EXP202414356, in accordance with the provisions of Article 85 of the LPACAP.

THIRD: TO ORDER A.A.A. to notify the Agency of the adoption of the measures described in the legal grounds of the initiation agreement transcribed in this resolution within 3 months from the date this resolution becomes final and enforceable.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sede.aepd.gob.es

45/45

FOURTH: TO NOTIFY this resolution to A.A.A.

FIFTH: In accordance with the provisions of Article 85 of the LPACAP, which conditions the reduction for voluntary payment and acknowledgment of responsibility upon the withdrawal or renunciation of any action or appeal in the administrative pathway, this resolution will be final in the administrative pathway and fully enforceable from its notification.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative pathway as provided by Article 114.1.c) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the interested parties may file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and paragraph 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

However, in accordance with the provisions of Article 90.3.a) of the LPACAP, the final resolution in the administrative pathway may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Agency's Electronic Registry

[<https://sede.aepd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency is not aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension terminated.

1259-260325

Lorenzo Cotino Hueso

President of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sede.aepd.gob.es